

Informe MITRE ATT\&CK.

MITRE ATT\&CK, desde 2025, se ha consolidado como el “idioma” operativo para medir la capacidad de detección y respuesta, y está empezando a utilizarse como base de indicadores a escala país en la UE, incluida España, aunque todavía de forma desigual y, en ocasiones, más aspiracional que real.¹²³⁴

1. MITRE ATT\&CK como base de indicadores

- MITRE ATT\&CK es una base de conocimiento global de tácticas, técnicas y sub técnicas adversarias, construida a partir de observaciones de ataques reales, que hoy supera centenares de TTP y se actualiza de forma continua.⁵⁶¹
- La matriz Enterprise (v13) organiza 14 tácticas y cerca de 200 técnicas con más de 400 sub técnicas, cubriendo entornos on-prem, nube, contenedores e identidades.⁶¹
- ENISA adopta MITRE ATT\&CK como “grid” de referencia para mapear comportamientos de amenaza en sus Threat Landscapes, que sirven como brújula estratégica para los Estados miembros.²³
- A nivel de producto, las Evaluaciones MITRE ATT\&CK Enterprise se han convertido en un benchmark de facto, centrado en métricas de cobertura de detección, calidad de alertas y protección preventiva.⁷⁸⁹

Ejemplo ilustrativo: en la evaluación Enterprise 2025 algunos proveedores logran 100% de cobertura de técnicas y protección, con cero falsos positivos en los escenarios probados, lo que marca el listón de lo que se exige a un SOC “serio” en 2026.⁵⁶⁷

1 <https://attack.mitre.org>

2 https://www.enisa.europa.eu/sites/default/files/publications/ENISA_CTL_Methodology_RECAST.pdf

3 https://www.enisa.europa.eu/sites/default/files/2026-01/ENISA_Threat_Landscape_2025_v1.2.pdf

4 <https://www.cynet.com/mitre-attck-results/>

5 https://www.enisa.europa.eu/sites/default/files/publications/ENISA_CTL_Methodology_RECAST.pdf

6 https://digital.gob.es/en/comunicacion/notas-prensa/mtdfp/2025/05/2025-05-06_02

7 <https://www.crowdstrike.com/en-us/blog/crowdstrike-achieves-100-percent-2025-mitre-attack-enterprise-evaluation/>

Tabla: niveles donde se usa ATT\&CK

Nivel	Uso principal ATT\&CK
Producto / SOC	Medir cobertura de detección, calidad de alertas
Organización	Roadmap de detección, priorización de casos de uso SIEM/SOAR
Sector / UE (ENISA)	Tipificación de TTP, análisis de tendencias
País (España y UE)	Alineación con planes nacionales, evaluación de capacidades

2. Métricas “clásicas” apoyadas en MITRE ATT\&CK

Desde 2025 se está convergiendo hacia un pequeño canon de métricas operativas donde ATT\&CK no aparece sólo como taxonomía bonita, sino como **eje de medición**.⁸⁹¹⁰

2.1 Cobertura de detección ATT\&CK

- Porcentaje de técnicas/subtécnicas relevantes para el entorno que generan, al menos, un evento observable y una lógica de detección asociada.¹¹⁹
- En las Evaluaciones Enterprise 2025 se reporta cobertura de técnicas a nivel granular: 90/90 técnicas detectadas, 100% de técnica-coverage, etc., y esto ha contaminado positivamente el lenguaje de los CISOs.¹⁰⁷⁸
- En España, soluciones gestionadas tipo xMDR ya anuncian porcentajes explícitos de cobertura de tácticas (~93%) y de técnicas (~66%), lo que muestra una adopción explícita del marco como métrica comercial y técnica.¹³

2.2 Calidad de detección y señal-ruido

- MITRE ha enfatizado desde 2025 métricas sobre calidad de detección (precisión, nivel de detalle en la técnica/subtécnica) y volumen de alertas, en lugar de “más es mejor”.⁹
- ENISA, al mapear incidentes a TTP ATT\&CK, impulsa a medir qué técnicas se detectan de forma temprana y cuáles sólo se descubren a posteriori, tras exfiltración o impacto.³²
- Fabricantes punteros presumen de detección con 100% de técnicas, 0 falsos positivos y detección a nivel de técnica/subtécnica, reforzando la idea de que la métrica ya no es sólo “ver algo”, sino “ver lo que importa, a la resolución correcta”.⁷⁸

⁸ <https://www.cynet.com/mitre-attck-results/>

⁹ <https://evals.mitre.org/enterprise/er7>

¹⁰ <https://radar.offsec.com/threat/mitre-posts-results-of-2025-attck-enterprise-evalu-0eb3a600>

2.3 Métricas de tiempo (MTTD, MTTC, MTTR)

- Prácticamente todos los marcos de métricas de 2025–2026 incorporan Mean Time to Detect (MTTD), Mean Time to Contain (MTTC) y Mean Time to Recover (MTTR); la aportación de ATT\&CK es permitir desglosar estos tiempos por táctica/técnica.¹⁴¹¹
- El análisis reciente de cobertura destaca que, ante el auge de intrusiones “malware-free” (~81% en 2024–2025), es crítico reducir MTTD en técnicas de credenciales, movimiento lateral y “living-off-the-land”, más que en firmas de malware clásico.¹²

3. Indicadores avanzados basados en ATT\&CK

Desde 2025 la comunidad académica e industrial ha pasado de “dibujar matrices” a usar ATT\&CK como base para indicadores compuestos y modelos de decisión.¹¹¹²¹³

3.1 Índices de riesgo técnico por táctica

- Trabajos recientes proponen caracterizar dinámicamente ataques según secuencias de técnicas ATT\&CK, optimizando la selección de mitigaciones según la ruta probable del adversario.¹⁵
- ENISA usa el mapeo ATT\&CK para identificar qué tácticas concentran más actividad (p. ej., exfiltración y credenciales suman alrededor de un tercio de los casos analizados en su ETL 2025), señalando dónde deben concentrarse capacidades y métricas.²
- Esto permite definir indicadores como “riesgo residual por táctica”: combinación de frecuencia observada en el ecosistema europeo y brecha de cobertura de detección/prevención en la infraestructura nacional.³²

3.2 Cobertura nacional y sectorial ATT\&CK

- ENISA ha refinado su metodología para procesar conjuntos de datos de TTP según ATT\&CK, integrando CTI de proveedores, CERT nacionales y fuentes OSINT, con vistas a vistas sectoriales y, potencialmente, por Estado miembro.²³
- Para España, los informes de ciberamenazas de la UE destacan que la administración pública es uno de los sectores más atacados, con especial protagonismo de ransomware, exfiltración y operaciones de espionaje; mapeado a ATT\&CK, esto se traduce en concentración en tácticas de impacto, exfiltración y acceso a credenciales.⁴²
- La progresiva adopción de herramientas de análisis de cobertura alineadas con ATT\&CK facilita generar “mapas de calor” por país o sector, identificando las técnicas donde la detección es sistemáticamente pobre.¹¹³

¹¹ <https://stellarcyber.ai/mitre-attck-coverage-analyzer/>

¹² <https://kcyerrid.com/2026/03/22/detection-coverage-measuring-what-you-can-actually-see/>

¹³ <https://www.sciencedirect.com/science/article/pii/S0167739X25005667>

3.3 Métricas de madurez: ATT\&CK + Zero Trust

- Algunos white papers orientados a seguridad nacional combinan ATT\&CK con marcos de inteligencia de amenazas para definir indicadores de madurez: porcentaje de flujos críticos cubiertos, capacidad de microsegmentación efectiva frente a tácticas de movimiento lateral, etc.¹⁶²
- El enlace con Zero Trust es directo: medir cuántas de las técnicas de acceso inicial, credenciales y movimiento lateral pueden completar su “coreografía” antes de que los controles de identidad, red y endpoint activen una respuesta.¹⁶⁹

4. España en el tablero ATT\&CK

4.1 Marco institucional

- España se posiciona como país con fuerte compromiso en ciberseguridad según informes internacionales, apoyado por un Plan Nacional de Ciberseguridad y nuevas inversiones superiores a 1 100 millones de euros para fortalecer capacidades de prevención, detección y respuesta.⁴
- El ecosistema nacional articula varios centros clave: INCIBE, CCN-CERT y el Mando Conjunto del Ciberespacio, que cooperan con la UE y ENISA en el intercambio de CTI y en la alineación con metodologías basadas en ATT\&CK.¹⁷³⁴
- INCIBE aparece citado como actor nacional asociado al uso de ATT\&CK en iniciativas internacionales, lo que apunta a su utilización al menos como marco de referencia en programas de capacitación y servicios a empresas.¹⁷

4.2 Uso de ATT\&CK en España (indicios)

- Casos recientes de ataques a infraestructuras españolas (p. ej., incidentes de ransomware o brechas en ministerios y puertos) se analizan y comunican con referencias explícitas a técnicas ATT\&CK, incluyendo phishing, ejecución de scripts y persistencia en sistemas críticos.¹⁸¹⁹
- El sector privado español incorpora métricas basadas en ATT\&CK en servicios gestionados avanzados, declarando cobertura explícita en tácticas y técnicas como argumento de calidad y madurez.¹³
- Empresas y alianzas GRC-ciber en España alinean sus servicios con el Esquema Nacional de Seguridad, el GDPR y marcos como ATT\&CK para integrar cumplimiento, amenazas y capacidades técnicas en un mismo cuadro de mando.¹³⁴

4.3 Oportunidad: indicadores “nacionales ATT\&CK”

Partiendo de las tendencias europeas y el tejido español, un conjunto razonable de indicadores a nivel país podría incluir:

- Porcentaje de técnicas ATT\&CK prioritarias (top N por frecuencia en la UE) con detección sistemática en infraestructuras críticas nacionales.
- Tiempo medio de detección de cadenas de ataque que involucren credenciales y movimiento lateral, en comparación con la media de la UE.122
- Cobertura ATT\&CK del ecosistema de servicios gestionados que dan soporte a pymes y administraciones locales (en porcentaje de tácticas técnicas relevantes).1113
- Índice de alineación entre incidentes reportados a CERT nacionales y su mapeo ATT\&CK frente al panorama europeo (¿detectamos lo mismo, más tarde, antes?).342

5. Tendencias globales desde 2025

5.1 Evaluaciones ATT\&CK como presión selectiva

- Las Evaluaciones Enterprise 2025 amplían el foco a dominios híbridos (endpoint, identidad, nube) e incorporan táctica de Reconocimiento, presionando para medir detección desde las fases más tempranas del ciclo de ataque.2079
- Varios fabricantes alcanzan 100% de detección y protección en los escenarios testados, lo que eleva la expectativa mínima y convierte cualquier cosa por debajo de cierto umbral de cobertura en una confesión de culpa.8107
- Aunque las evaluaciones no nombran “ganadores”, la transparencia de los datos por técnica permite a gobiernos y grandes organizaciones seleccionar tecnologías según su propio modelo de amenaza.89

5.2 Europa y ENISA: ATT\&CK como lingua franca

- ENISA sitúa ATT\&CK en el centro de su metodología de Threat Landscape, normalizando los TTP reportados por Estados miembros, proveedores y OSINT.23
- La sectorialización (p. ej., administración pública) permite extraer patrones de TTP que, traducidos a ATT\&CK, pueden convertirse en listas de “técnicas mínimas” que deberían estar cubiertas en cualquier SOC gubernamental europeo.212
- Esta convergencia prepara el terreno para métricas comparativas entre países, aunque todavía no se ha publicado un ranking explícito por cobertura ATT\&CK.222

5.3 Academia e industria: operacionalizar ATT\&CK

- Estudios recientes muestran que ATT\&CK es uno de los marcos más adecuados para procesar datos de amenazas a gran escala, especialmente aprovechando técnicas de IA para clasificar y correlacionar TTP.2315
- La caracterización dinámica de ataques basada en ATT\&CK permite optimizar la selección de mitigaciones y priorizar inversiones en funciones de seguridad con mayor impacto marginal.1215
- Herramientas industriales han aparecido específicamente para mapear, medir y reportar cobertura ATT\&CK, proporcionando reporting exportable para auditorías y decisiones de inversión.11

2425262728293031323334353637383940414243